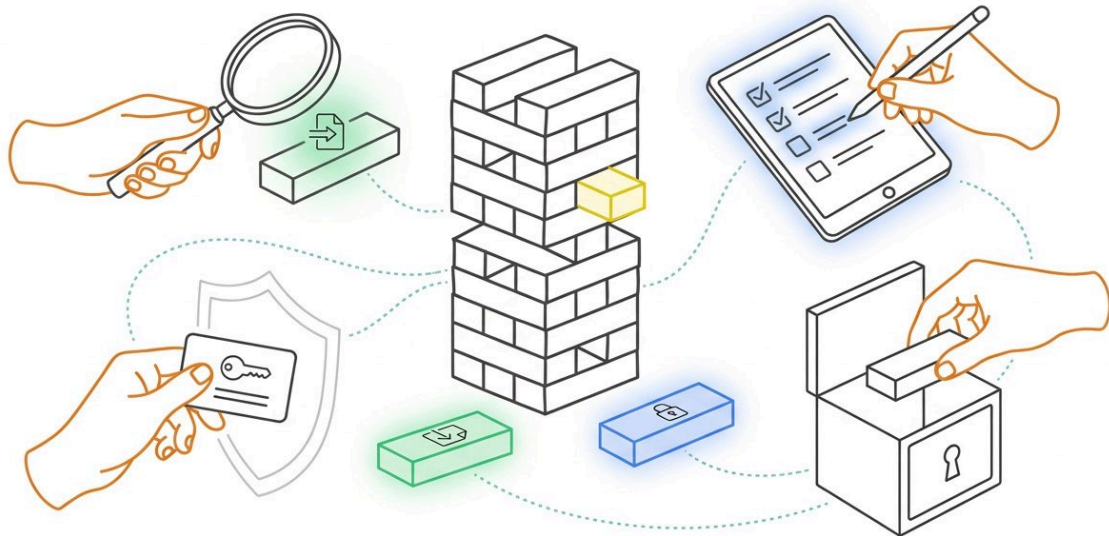


Mapping NIST CSF 2.0 to GRC Risk for Compliance

How a small practice proves its security posture with documentation that holds up to a client, an insurer or an auditor.



GV
Govern

ID
Identify

PR
Protect

DE
Detect

RS
Respond

RC
Recover

ANÈL HENNING

MS Cybersecurity Management capstone · Purdue Global · IT 595

Logical **Coders**

Frameworks describe outcomes. Small practices need proof.

Clients, insurers and auditors increasingly ask small organizations to **demonstrate** that they manage cybersecurity risk. Most have no security staff and no time to turn hundreds of pages of NIST guidance into documents they can keep current.

This paper describes a reusable toolkit I built for **Logical Coders**, a compliance documentation practice. It uses **CSF 2.0** as the organizing structure and **NIST SP 800-53 Rev. 5** for the testable controls, narrowed to three families: Access Control, Risk Assessment, and Audit and Accountability.

Applied to a fictional 22-person dental practice, the toolkit turned framework language into a scored risk register, three control narratives, a tested access control and a one-page report leadership can sign.

THE CLAIM

A small, consistent set of templates — every control tied to a risk, an owner and its evidence — is more defensible than custom documentation rebuilt for each client.

- ✓ Repeatable across clients
- ✓ Compatible with SOC 2 and FedRAMP language
- ✓ Maintainable without a security team

BY THE NUMBERS

12

audit templates, each with a HIPAA and NIST reference field

3

control families in scope: AC, RA and AU

7

exceptions found by re-performing AC-2 in code

3 → 0

critical risks, projected after treatment

WHO IT IS FOR

Small practices with clients, insurers or partners that require a documented security posture.

WHAT IT COVERS

CSF 2.0 functions, SP 800-53 AC-2, RA-3 and AU-6, and the HIPAA Security Rule as client criteria.

WHAT IT IS NOT

A full control catalog or automated compliance — it is documentation a small team can maintain.

Long frameworks, short staff, inconsistent documents

NIST guidance is written for organizations with dedicated security teams. A small practice that copies it piecemeal ends up with documents that disagree with each other — and inconsistent or inaccurate documentation is exactly what falls flat in a SOC 2 examination or a FedRAMP authorization (AICPA & CIMA, n.d.; GSA, n.d.).

THREE SOURCES OF PRESSURE

Clients

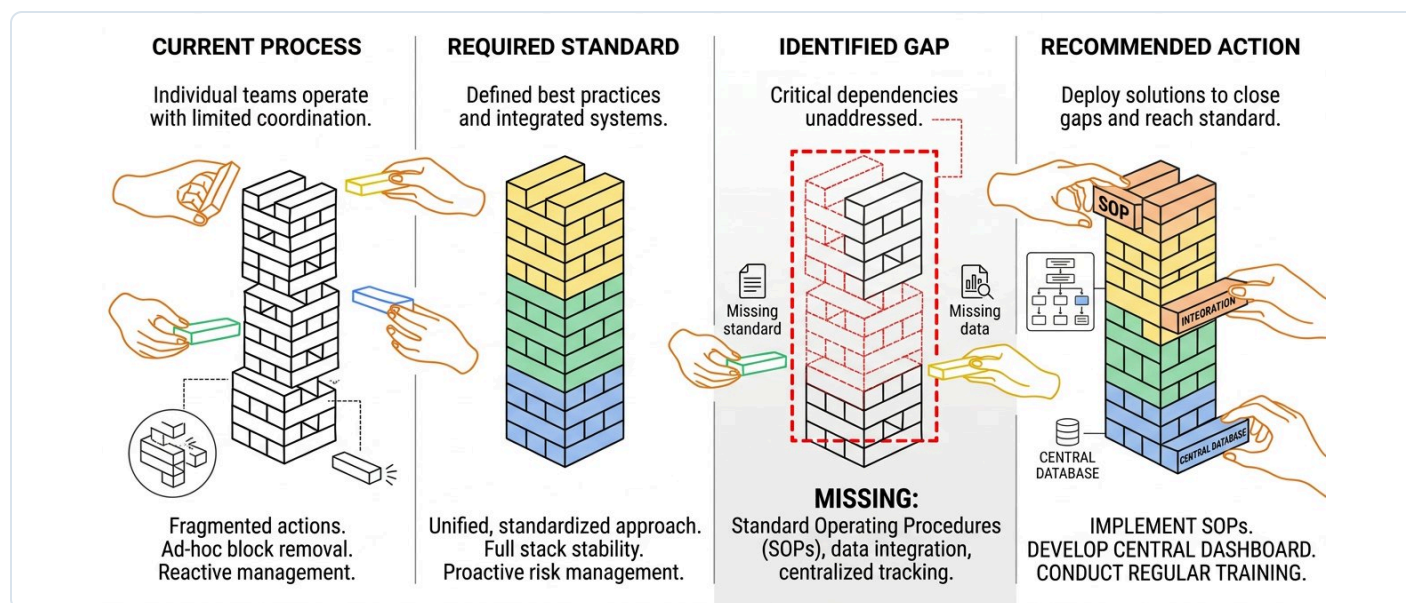
ask vendors for SOC 2-style answers before sharing sensitive data

Insurers

send cyber-insurance questionnaires that expect documented controls

Auditors

need evidence that a control operated, not a policy that says it should



CAPTION From fragmented, reactive practice to a defined standard — the gap this toolkit closes (2026)

WHAT GOES WRONG TODAY

Risks are listed but never scored. Controls are described but have no owner. Evidence exists but cannot be traced to a requirement. When a client asks for proof, the practice starts over.

WHAT THE TOOLKIT CHANGES

Every template carries the same document-control block, evidence rule and HIPAA/NIST reference field, so a risk, its control, its evidence and the decision about it always connect.

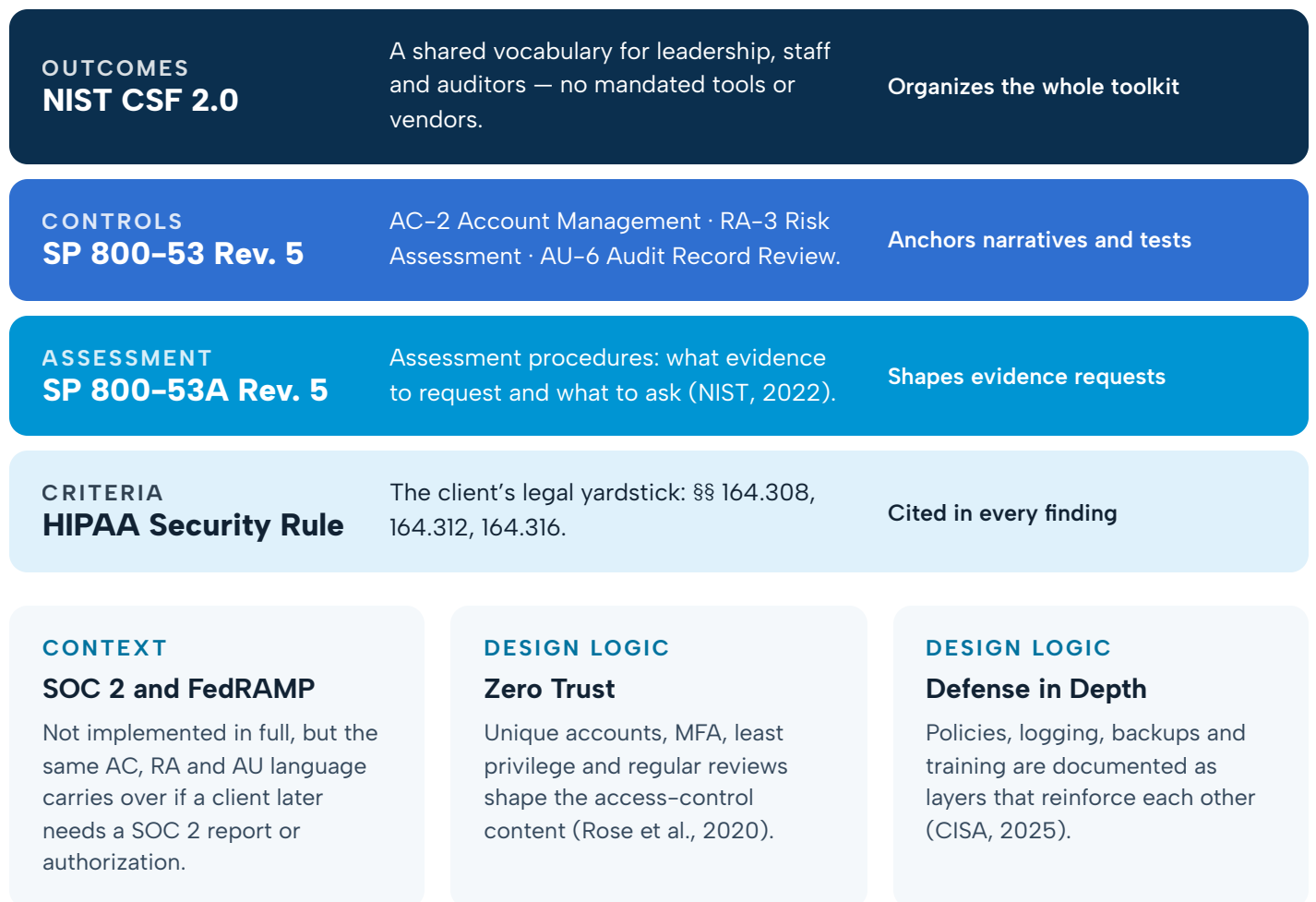
Two altitudes: outcomes above, testable controls below

CSF 2.0 describes the outcomes an organization should achieve; SP 800–53 supplies the specific, testable controls that show those outcomes are actually met (NIST, 2020, 2024). The toolkit uses each at its own altitude.

CSF 2.0 — SIX FUNCTIONS (NIST, 2024)



Govern is the newest function and the most consequential here: it ties daily security back to who owns which risk.



From a CSF outcome to the evidence that proves it

This is the core of the toolkit. Read each row left to right: the outcome NIST describes, the control that achieves it, the HIPAA requirement a client is judged against, the template that documents it, and the evidence an auditor will ask to see.

CSF outcome → 800-53 control → HIPAA criterion → Template → Evidence

Function	Category	Control	HIPAA	Template	Evidence
Govern	GV.OV · GV.RR · GV.PO	—	§ 164.308(a)(2), (a)(8); § 164.316	01 Program · 02 Plan · 11 Governance · 12 Package	Signed governance report; document register
Identify	ID.RA	RA-3	§ 164.308(a)(1)(ii)(A)–(B)	05 Risk Register	Register with approval date and residual scores
Identify	ID.IM	RA-3	§ 164.308(a)(8)	06 Gap Analysis · 07 Tracker	Finding statements; dated tracker items
Protect	PR.AA	AC-2	§ 164.308(a)(3)(ii)(C); § 164.312(a)(1)	04 Narrative · 09 Lifecycle · 08 Effectiveness	Signed request, disable ticket, script output
Detect	DE.CM	AU-6	§ 164.312(b); § 164.308(a)(1)(ii)(D)	10 Audit Log Summary	Weekly log-review record; escalation tickets

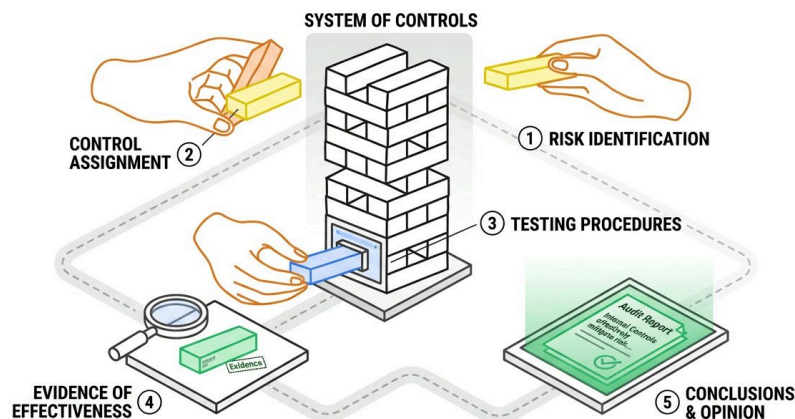
Respond

Recover

Outside the three-family scope, but surfaced where they affect posture: incident response and backup are rated in the governance report.

WHY ONLY THREE FAMILIES?

SP 800-53 has hundreds of controls. A defined subset tied to Identify, Protect and Detect keeps the toolkit finishable, testable and reusable.



CAPTION The System of Controls — each mapping row is one path through this tower (2026)

One package, one evidence rule, four milestones

TWELVE TEMPLATES IN FIVE PHASES

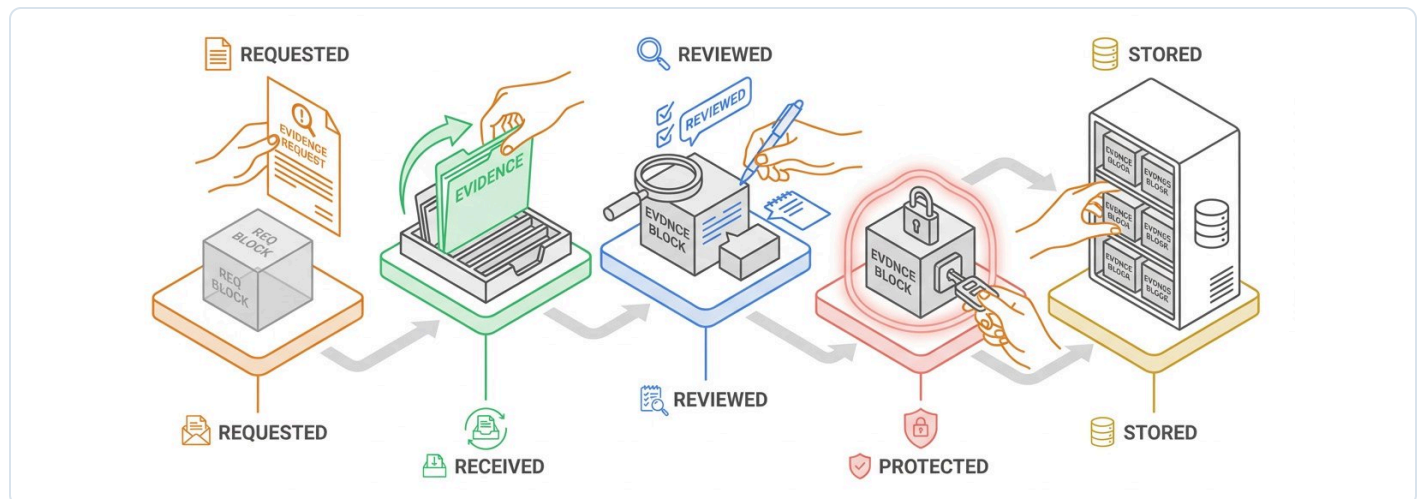
● Plan	01 Audit Program · 02 Audit Plan
● Evidence	03 Fieldwork · 08 Effectiveness · 10 Log Summary
● Control	04 Narrative · 09 Account Lifecycle
● Risk	05 Risk Register · 06 Gap Analysis
● Decision	07 Tracker · 11 Governance · 12 Package

EVIDENCE-HANDLING RULE

No ePHI, passwords, private keys, full Social Security numbers or unnecessary screenshots in workpapers. Minimum necessary, redact, restrict, store in an approved repository.

EVERY TEMPLATE CARRIES

- ✓ Plain-language definition
- ✓ Document-control block, 6-year retention
- ✓ HIPAA / NIST reference field
- ✓ Prepared, reviewed, approved sign-off



CAPTION Audit Evidence Journey — the path every sample exhibit followed (2026)

CAPSTONE TIMELINE

M1 Sep 16 Research foundation CSF 2.0, SP 800-53, Zero Trust, Defense in Depth	M2 Sep 25 Twelve templates Risk register, account review, log summary and tracker samples	M3 Oct 5 Narratives and testing AC-2, RA-3, AU-6 narratives; AC-2 tested in Python and SQL	M4 Oct 2026 Final package All samples, quality review, web portfolio, client guide
--	---	--	--

Sunshine Dental Group: what the toolkit found

Sunshine Dental Group is a fictional 22-person practice running a cloud EHR, email and a patient portal, supported by an outside IT vendor. I completed every template for it. No real patient or company data is used.

RISK REGISTER · INHERENT VS. RESIDUAL

R-01 Ransomware · EHR



R-03 Lost device



R-04 Phishing · email



AC-2 RE-PERFORMED IN CODE · EXCEPTIONS



7

exceptions across 8 accounts and 5 roster entries, including a terminated user active for 19 days

CONTROL HEALTH IN THE GOVERNANCE REPORT

Access management · Red

Audit logging · Red

MFA · Red

Backup · Yellow

Incident response · Yellow

OVERALL HIPAA POSTURE

Red improving

Decisions requested of the Dentist-Owner: name a security official, approve the risk treatments, fund MDM and MFA, and sign vendor Business Associate Agreements.

90-DAY REMEDIATION PLAN

5 items

all due within 30 days — one Critical (MFA), four High — each with an owner in the Audit Tracker.

Six moves any small practice can make this quarter

- 1 **Start with Govern**
Name a security official and an owner for every risk before buying tools.
- 2 **Score before you spend**
Rate likelihood × impact so the first dollars go to Critical risks.
- 3 **Write narratives that name evidence**
A control is not documented until it says what proves it ran.
- 4 **Re-perform, don't ask**
Run the access-control script monthly; review logs weekly.
- 5 **Report on one page**
Give leadership posture, top risks and the decisions needed.
- 6 **Repeat the cycle**
Review on a schedule so the program improves each round.

CONCLUSION

CSF 2.0 supplies the structure, SP 800-53 supplies the controls, and HIPAA supplies the criteria. The toolkit's contribution is the connection: every risk has a control, every control has an owner and evidence, and every finding reaches someone who can decide. That connection is what makes a small practice's documentation hold up.

REFERENCES

- American Institute of CPAs & Chartered Institute of Management Accountants. (n.d.). *SOC 2 – SOC for service organizations: Trust services criteria*.
- Cybersecurity and Infrastructure Security Agency. (2025, September 10). *Cyber essentials*.
- Kindervag, J. (2010). *No more chewy centers: Introducing the zero trust model of information security*. Forrester Research.
- National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations* (SP 800-53 Rev. 5).
- National Institute of Standards and Technology. (2022). *Assessing security and privacy controls in information systems and organizations* (SP 800-53A Rev. 5).
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (CSWP 29).
- Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST SP 800-207).
- Security Standards: Administrative Safeguards, Technical Safeguards and Documentation, 45 C.F.R. §§ 164.308, 164.312, 164.316 (2024).
- U.S. General Services Administration. (n.d.). *FedRAMP: Federal Risk and Authorization Management Program*.



Anèl Henning · Logical Coders

Case data is fictional. Companion pieces: Compliance Analyst and IT Auditor books.

linkedin.com/in/anel-henning-quantum
anelhenning2-collab.github.io/portfolio